

Privacy Classification of HTTP Request Metadata for a Zero-Knowledge File Sharing Service

Research Brief — SGraph Send

1. Privacy Classification of Each Field

Regulatory Framework Summary

The key definitions across jurisdictions:

GDPR (Art. 4(1)): Personal data is "any information relating to an identified or identifiable natural person." Recital 30 explicitly includes "online identifiers" (IP addresses, cookie identifiers) as potential personal data.

UK GDPR / DPA 2018: Mirrors GDPR Art. 4(1). The ICO applies a "motivated intruder" test for identifiability — would a determined person with access to publicly available resources be able to identify an individual?

CCPA/CPRA (§1798.140(v)): "Personal information" includes identifiers such as IP addresses, geolocation data, and browsing history. Broader than GDPR in some respects — explicitly enumerates IP addresses as PI.

LGPD (Art. 5(I)): "Personal data" is information related to an identified or identifiable natural person. Closely mirrors GDPR. Art. 12(2) addresses anonymisation.

ePrivacy Directive (2002/58/EC): Governs the confidentiality of communications and traffic data. IP addresses are traffic data under Art. 6 and require consent or necessity for storage beyond what's needed for transmission.

Is an IP Address Always PII Under GDPR?

Short answer: effectively yes, for any service operator.

The CJEU ruling in *Breyer v Bundesrepublik Deutschland* (C-582/14, 19 Oct 2016) established that even **dynamic** IP addresses constitute personal data in the hands of a website operator, provided legal means exist to combine that IP with ISP-held subscriber data to identify the visitor. The court adopted a **relative approach** — identifiability is assessed from the controller's perspective, considering all means "reasonably likely to be used" (Recital 26 GDPR).

The practical consequence, as the Article 29 Working Party noted in Opinion WP136, is that operators rarely know at collection time whether identification is feasible for a given IP. Therefore, the safe operational assumption is: **treat all IP addresses as personal data.**

Narrow exceptions may exist for Tor exit node IPs or commercial VPN server IPs where no operator can identify the user, but these are edge cases you cannot reliably detect at collection time.

Under **CCPA**, IP addresses are explicitly enumerated as personal information — no analysis needed.

Under **LGPD**, the same logic as GDPR applies; IP addresses are personal data if identification is reasonably possible.

Per-Field Classification

#	Field	GDPR	CCPA	Classification	Notes
1	IP address	PII (Recital 30, Breyer)	PI (§1798.140(v))	PII	Always treat as personal data
2	User-Agent	Quasi-identifier	PI (device identifier)	Quasi-identifier	~10 bits entropy alone (EFF Panopticlick); PII when combined with IP+language+timezone
3	Accept-Language	Quasi-identifier	Not PI alone	Quasi-identifier	~3–5 bits entropy; narrows population significantly for rare language combos
4	Referer	PII (may contain user-identifying URLs)	PI	PII	Could contain search queries, authenticated URLs, or user-specific paths
5	Timestamp	Non-personal alone	Non-personal alone	Non-personal	Second-precision timestamps are quasi-identifiers if combined with other fields; minute/hour granularity is safe
6a	Country (CF header)	Non-personal	Non-personal	Non-personal	Population > millions; insufficient to identify
6b	Region/State	Quasi-identifier	Non-personal in most cases	Non-personal (borderline)	Population typically > 100k; safe for large regions
6c	City	Quasi-identifier	PI if < ~50k pop	Quasi-identifier	Cities like London (9M) are safe; small towns (< 10k) are identifying
6d	Postal code	PII (UK: ~15 households)	PI (ZIP+4 is PII)	PII	UK postcodes are highly granular; US ZIP codes vary (ZIP is less identifying, ZIP+4 is PII)
6e	Lat/Long (IP-derived)	PII	PI	PII	Even at ~5km accuracy, combined with time can identify
6f	Timezone	Quasi-identifier	Not PI alone	Non-personal	~3 bits entropy; large populations per timezone
6g	Device type (mobile/desktop/tablet)	Quasi-identifier	Not PI alone	Non-personal	~1.5 bits entropy; very broad categorisation
6h	ASN (CloudFront header)	Quasi-identifier	Non-personal	Quasi-identifier	Large ISPs are non-identifying; small corporate

#	Field	GDPR	CCPA	Classification	Notes
					ASNs could identify an organisation (and by extension, individuals)
7	TLS metadata	Non-personal	Non-personal	Non-personal	Cipher suite and version have minimal entropy
8	Request metadata (method, path, content-length)	Quasi-identifier	Non-personal	Non-personal	Path contains transfer ID (by design public); content-length is not identifying
9	Geolocation (enriched)	Same as 6a–6e	Same as 6a–6e	See above	Depends on granularity
10	ISP/Organisation	Quasi-identifier	Non-personal	Quasi-identifier	Large ISP = safe; small company name = quasi-identifier
11	ASN (enriched)	Same as 6h	Same	Quasi-identifier	Same as CloudFront ASN
12	Connection type	Non-personal	Non-personal	Non-personal	Residential/business/hosting — very broad categories
13	VPN/Proxy/Tor flag	Non-personal	Non-personal	Non-personal	Boolean flag; no identifying information
14	Threat intelligence	Non-personal	Non-personal	Non-personal	Relates to IP reputation, not to a person

2. The Anonymisation Boundary

Anonymisation vs Pseudonymisation Under GDPR

Pseudonymisation (Art. 4(5) GDPR): Processing personal data such that it "can no longer be attributed to a specific data subject without the use of additional information," provided that additional information is kept separately. **Pseudonymised data is still personal data** — the GDPR applies in full.

Anonymisation (Recital 26 GDPR): Data rendered irreversibly unidentifiable, where identification is not reasonably possible by any means. Anonymous data falls **outside the scope of GDPR entirely**.

The EDPB's January 2025 Guidelines 01/2025 on Pseudonymisation reinforce this distinction firmly: pseudonymisation is a *safeguard*, not an exemption. The ICO's March 2025 guidance introduces a slight divergence — the ICO accepts "effective anonymisation" where re-identification is "sufficiently remote," even if not mathematically impossible. The EDPB rejects this relative framing.

Does SHA-256(IP) Achieve Anonymisation?

No. Plain hashing of an IP address is pseudonymisation, not anonymisation.

The reasoning is straightforward:

1. **IPv4 has only ~4.3 billion possible values.** SHA-256 of every possible IPv4 address can be precomputed in minutes (a rainbow table). Even SHA-256(IP) without salt is trivially reversible via brute force.
2. **With a static salt**, the problem is equivalent — if the salt is known (or compromised in a full-server breach, which is your threat model), the entire lookup table can be rebuilt.
3. **The Dutch DPA (Autoriteit Persoonsgegevens) explicitly warns:** "Hash values are reproducible. You can derive the original data from a new calculation of the hash values of all possible original data until you have a match."

Does a Rotating, Discarded Salt Change the Analysis?

This is where it gets interesting. Consider $\text{HMAC-SHA256}(\text{IP}, \text{daily_salt})$ where the salt is:

- Generated fresh each day
- Held only in Lambda ephemeral memory or a short-lived Secrets Manager entry
- **Irrevocably destroyed** at rotation

If the salt is truly destroyed and unrecoverable:

The stored HMAC output cannot be reversed to the original IP because:

- Without the salt, you cannot construct the rainbow table
- HMAC is not equivalent to $\text{SHA256}(\text{salt} + \text{IP})$ — it uses a keyed construction that prevents length-extension attacks
- The input space (IPv4) is small, but without the key, brute-forcing HMAC-SHA256 is computationally infeasible

This approaches true anonymisation under certain conditions, but regulators remain cautious:

- The **EDPB position** is that if the entity that performed the hashing ever had the key, the data was personal data at the moment of processing, and the GDPR applied at that point. Destroying the key later doesn't retroactively remove the GDPR obligations that existed during processing.
- The **ICO** is more pragmatic — under the "motivated intruder" test, if the salt is genuinely destroyed and no copy exists, re-identification is "sufficiently remote" and the data may be considered effectively anonymous *going forward*.

HMAC with Server-Held Key vs SHA-256 with Discarded Salt

Approach	Reversible?	GDPR Status	Analytic Utility
$\text{SHA-256}(\text{IP})$ — no salt	Yes (rainbow table in minutes)	Pseudonymised (PII)	Same-IP correlation across all time
$\text{SHA-256}(\text{IP} + \text{static_salt})$	Yes if salt compromised	Pseudonymised (PII)	Same-IP correlation across all time
$\text{HMAC-SHA256}(\text{IP}, \text{persistent_key})$	Yes if key compromised	Pseudonymised (PII)	Same-IP correlation across all time; stronger than SHA256

Approach	Reversible?	GDPR Status	Analytic Utility
<code>HMAC-SHA256(IP, daily_salt)</code> — salt destroyed	No (if salt truly gone)	Arguably anonymous (ICO); still pseudonymous at creation (EDPB)	Same-IP correlation within one day only
<code>SHA-256(IP + daily_salt)</code> — salt destroyed	No (if salt truly gone)	Same as above	Same as above; HMAC preferred for cryptographic correctness

Recommendation for SGraph Send

Use `HMAC-SHA256(IP, daily_salt)` where the salt is generated in-memory at Lambda cold start (or fetched from a short-TTL secret), used for the day, and irrevocably destroyed. This gives you:

- **Within a single day:** ability to correlate upload and download events from the same IP (useful for abuse detection — "same IP uploaded and downloaded" without knowing the IP)
- **Across days:** no correlation possible; the hashes are meaningless
- **Under full compromise:** the stored HMACs cannot be reversed to IPs

Document the salt lifecycle (generation, storage, destruction) thoroughly. This documentation is your defence if a DPA ever challenges the anonymisation claim.

3. Geolocation Granularity — Where Is the Line?

Analysis by Granularity Level

Level	Example	Typical Population	k-Anonymity	PII?	Safe to Store?
Country	"United Kingdom"	~67M	k > 1M	No	✅ Yes
Region/State	"England"	~56M	k > 100k	No	✅ Yes
Region/State	"Rutland" (smallest English county)	~41k	k > 10k	Borderline	⚠️ Likely safe but document the reasoning
City	"London"	~9M	k > 100k	No	✅ Yes
City	"Small town" (< 5k)	< 5k	k < 5k	Quasi-identifier	❌ No — generalise to region
Postal code	UK "SW1A 1AA"	~15 households	k < 100	Yes	❌ Never store
Postal code	US "90210"	~21k	k > 10k	Quasi-identifier	⚠️ Varies wildly
Lat/Long (IP-derived)	51.5074, -0.1278	Varies by precision	Depends on decimal places	Yes	❌ Never store

The k-Anonymity Threshold

There is no universally mandated k-value, but established practice from statistical disclosure control and various DPA guidance converges around:

- **$k \geq 1,000$** is generally considered safe for public data releases (Eurostat guidance, US Census disclosure avoidance)
- **$k \geq 10,000$** provides a comfortable margin
- **$k < 100$** is clearly identifying (a UK postcode at ~15 households fails catastrophically)

For SGraph Send, the pragmatic threshold is: **store geographic data only at granularities where the described population is reliably > 10,000 people.**

Recommendation

Safe to store in plaintext: Country, Region/State (for large regions only — England, California, etc.), Device type, Timezone.

Conditionally safe: City — only if you threshold to cities above a certain population. IP-derived city data from CloudFront or MaxMind often returns large cities anyway (IP geolocation is rarely accurate below city level). Implement a check: if the city population is below 50,000, generalise to region.

Never store: Postal codes, lat/long coordinates, any sub-city precision.

4. Three-Tier Storage Classification

Tier 1 — Store in Plaintext

These fields are non-sensitive and safe to expose in a full breach:

Field	Stored Value	Justification
Timestamp	ISO 8601 UTC, truncated to nearest hour	Hour granularity removes timing correlation risk; sufficient for "downloads over time" analytics
Country	<code>"GB"</code> , <code>"US"</code> , etc.	Population > millions; non-identifying
Region/State	<code>"England"</code> , <code>"California"</code>	Population > 100k; non-identifying for large regions
Device type	<code>"mobile"</code> / <code>"desktop"</code> / <code>"tablet"</code>	~1.5 bits; non-identifying
Connection type	<code>"residential"</code> / <code>"business"</code> / <code>"hosting"</code>	Broad categories; non-identifying
VPN/Proxy/Tor flag	<code>true</code> / <code>false</code>	Boolean; non-identifying; useful for abuse detection
TLS version	<code>"TLSv1.3"</code>	Non-identifying; useful for security posture
Transfer direction	<code>"upload"</code> / <code>"download"</code>	Inherent to the event
Content-length	Bytes (integer)	File size is already known (encrypted payload is in S3)

Tier 2 — Store as Anonymised Hash

These fields are PII or quasi-identifiers that have analytic value when hashed:

Field	Stored Value	Hashing Scheme	Analytics Enabled
IP address	<code>HMAC-SHA256(IP, daily_salt)</code>	HMAC-SHA256 with daily rotating salt; salt destroyed after 24h	Same-IP upload/download correlation within a day; daily unique IP counts
User-Agent	Normalised category string stored as plaintext (see §5)	N/A — store normalised form	Browser/OS distribution analytics
ASN	<code>HMAC-SHA256(ASN_number, daily_salt)</code>	Same scheme as IP	Abuse detection (multiple transfers from same network); not stored raw because small corporate ASNs could identify organisations

Hashing scheme details:

- **Algorithm:** HMAC-SHA256
- **Key material:** 256-bit cryptographically random salt, generated via `os.urandom(32)` or AWS Secrets Manager
- **Rotation:** Every 24 hours at 00:00 UTC
- **Salt storage during active period:** Lambda environment variable (ephemeral) or Secrets Manager with 24h TTL and auto-deletion
- **Salt destruction:** Lambda environment dies with the execution context; Secrets Manager entry auto-deleted by scheduled Lambda
- **Output format:** Hex-encoded HMAC, truncated to first 16 characters (64 bits) — sufficient for correlation while reducing any residual information

Tier 3 — Never Store

These fields are discarded after request processing:

Field	Ephemeral Use	Why Not Stored
Raw IP address	Rate limiting (in-memory counter in Lambda); transparency panel display	PII; reversal risk under full compromise
Full User-Agent string	Transparency panel display; parsed into normalised form	Fingerprinting vector; ~10 bits entropy
Accept-Language	Transparency panel display	Quasi-identifier; limited analytic value
Referer	Logged for debugging only if error occurs (and only to CloudWatch with 24h retention)	May contain identifying URLs
City (if pop < 50k)	Transparency panel display	Quasi-identifier for small cities
Postal code	Not used	PII (especially UK postcodes)
Latitude/Longitude	Not used	PII
ISP/Organisation name	Transparency panel display	Quasi-identifier for small orgs
Raw ASN number	Parsed into hash	Quasi-identifier

Ephemeral processing is permitted. GDPR applies to any "processing" of personal data, including ephemeral use. However, if the data never hits persistent storage (S3, DynamoDB, CloudWatch), and is processed only in Lambda memory for the duration of a single request (~100ms), the privacy risk is negligible and the lawful basis is straightforward (legitimate interest under Art. 6(1)(f) for security and service provision). Document this in your DPIA.

5. The User-Agent Problem

Entropy Analysis

The EFF's Panopticlick study (Eckersley, 2010) measured User-Agent at **~10.0 bits of entropy** — meaning the User-Agent string alone narrows identification to roughly 1 in 1,024 browsers. Modern studies (AmiUnique, 2016) confirm similar figures.

However, User-Agent entropy has **decreased** somewhat since Chrome's User-Agent reduction initiative (Chrome 107+, 2022), which froze minor version numbers and reduced OS detail. A modern Chrome UA string looks like:

```
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0
Safari/537.36
```

This is shared by millions of users. The frozen format means less variation, but Safari, Firefox, and non-Chromium browsers still expose more detail.

The Combination Risk

The danger isn't User-Agent alone — it's the combination. UA + Accept-Language + Timezone + IP gives you potentially $10 + 4 + 3 + 32 \approx 49$ bits, which is more than sufficient to uniquely identify any human on Earth (33 bits needed for 8 billion people).

Even UA + Accept-Language + Country gets you $10 + 4 + \sim 8 \approx 22$ bits — unique among ~4 million people.

Recommendation: Normalised User-Agent

Do not store the full User-Agent string. Instead, parse it server-side into a normalised category and store only that:

```
python

# Parse UA into broad categories
def normalise_ua(ua_string: str) -> str:
    """Returns e.g. 'Chrome/Windows', 'Safari/macOS', 'Firefox/Linux'"""
    # Use ua-parser or httpagentparser
    parsed = parse(ua_string)
    browser_family = parsed.browser.family # "Chrome", "Safari", "Firefox", "Edge"
    os_family = parsed.os.family          # "Windows", "macOS", "Linux", "iOS", "Android"
    return f"{browser_family}/{os_family}"
```

This yields categories like `Chrome/Windows`, `Safari/iOS`, `Firefox/Linux` — each shared by millions of users, contributing < 4 bits of entropy. Combined with country alone, this stays well within safe k-anonymity bounds.

Do not store: browser version, OS version, WebKit/Gecko version, device model, or any other sub-components.

6. Transparency Panel — Show Live, Store Anonymised

The Approach

The "show live, store anonymised" pattern is both technically sound and legally defensible:

1. **HTTP request arrives** at your Lambda function
2. **Derive all metadata** from request headers (IP, UA, geolocation via CloudFront headers, etc.)
3. **Return the full metadata** to the client in the API response body (for the transparency panel)
4. **Store only the Tier 1 + Tier 2 fields** to S3

The client renders the transparency panel from the response payload. The raw PII exists only in Lambda memory for the duration of the request (~100ms) and in the response payload (which is the user's own data, returned to them).

Legal Analysis

Is this lawful?

Yes. There is no GDPR, UK GDPR, CCPA, or LGPD requirement to persist data that you display to a user. The relevant regulations concern:

- **Collection:** You are collecting the data momentarily — this is processing, and you need a lawful basis. Legitimate interest (Art. 6(1)(f)) covers this easily: providing the user with transparency about their own request metadata is directly in their interest.
- **Storage:** You are explicitly *not* storing the PII. The anonymised/aggregated version you do store is either outside GDPR scope (if truly anonymous) or pseudonymised with minimal risk.
- **Display:** You are showing users their *own* data. This is analogous to a "what's my IP" service — entirely standard.

Is there a requirement to store what you show?

No. In fact, **data minimisation (Art. 5(1)(c) GDPR)** actively encourages you to not store data you **don't need**. Showing data live and discarding it is the gold standard of privacy-by-design (Art. 25 GDPR).

The only caveat: if a user makes a **subject access request (SAR)** under Art. 15, you must provide any personal data you hold about them. If you've already discarded their IP, you have nothing to provide — which is fine. You are not obligated to retain data for the purpose of future SARs.

Technical Implementation Notes

- Ensure the API response containing raw metadata is served over TLS (obvious, but worth stating)
- The transparency panel should make clear: "This information was derived from your request. It is shown to you in real-time and is **not stored** on our servers."
- Consider a client-side-only option where the transparency panel data never even touches your API — derive it entirely in the browser via JavaScript (navigator.userAgent, Intl.DateTimeFormat().resolvedOptions().timeZone, etc.). IP would still need server-side derivation.

7. Practical Recommendation

Final Storage Schema

FIELD	SHOW TO USER	STORE ON SERVER	FORMAT STORED
IP address	✓ Yes	✓ Yes	HMAC-SHA256(IP, daily_salt), truncated to 16 hex chars
User-Agent (full)	✓ Yes	✗ No	—
User-Agent (normalised)	✓ Yes	✓ Yes	Plaintext category, e.g. "Chrome/Windows"
Accept-Language	✓ Yes	✗ No	—
Referer	✗ No	✗ No	— (discard; may contain sensitive URLs)
Timestamp	✓ Yes (full)	✓ Yes (truncated)	ISO 8601 UTC, truncated to hour
Country	✓ Yes	✓ Yes	ISO 3166-1 alpha-2 code, e.g. "GB"
Region/State	✓ Yes	✓ Yes	String, e.g. "England" (only for pop > 50k regions)
City	✓ Yes	⚠ Conditional	Plaintext only if city pop > 50k; else store "—"
Postal code	✓ Yes	✗ No	— (never store)
Latitude/Longitude	✗ No	✗ No	— (never store; never show — false precision)
ISP/Organisation	✓ Yes	✗ No	—
ASN	✗ No	✓ Yes	HMAC-SHA256(ASN, daily_salt), truncated to 16 hex chars
Connection type "education"	✓ Yes	✓ Yes	Plaintext: "residential" / "business" / "hosting" / "education"

VPN/Proxy/Tor flag	✔ Yes	✔ Yes	Boolean
Device type (mobile/desktop)	✔ Yes	✔ Yes	Plaintext: "mobile" / "desktop" / "tablet"
TLS version	✔ Yes	✔ Yes	Plaintext: "TLSv1.2" / "TLSv1.3"
Threat intelligence flag	✘ No	✔ Yes	Boolean: is_known_threat

Example **meta.json** (Stored in S3)

```

json
{
  "version": "1.0",
  "events": [
    {
      "type": "upload",
      "timestamp": "2025-02-09T14:00:00Z",
      "ip_hash": "a3f2b8c1d4e5f6a7",
      "asn_hash": "b7c8d9e0f1a2b3c4",
      "country": "GB",
      "region": "England",
      "city": "London",
      "device_type": "desktop",
      "browser_os": "Chrome/Windows",
      "connection_type": "residential",
      "is_vpn": false,
      "is_tor": false,
      "is_proxy": false,
      "is_known_threat": false,
      "tls_version": "TLSv1.3",
      "content_length": 4582912
    },
    {
      "type": "download",
      "timestamp": "2025-02-09T15:00:00Z",
      "ip_hash": "e9f0a1b2c3d4e5f6",
      "asn_hash": "b7c8d9e0f1a2b3c4",
      "country": "US",
      "region": "California",
      "city": "San Francisco",
      "device_type": "mobile",
      "browser_os": "Safari/iOS",
      "connection_type": "residential",
      "is_vpn": true,
      "is_tor": false,
      "is_proxy": false,
      "is_known_threat": false,
      "tls_version": "TLSv1.3",
      "content_length": 4582912
    }
  ]
}

```

Analytics Capabilities Preserved

With this schema, you can still compute:

- **Transfers per country/region** over time (direct from plaintext fields)
- **Downloads over time** (hourly granularity from truncated timestamps)
- **Device/browser distribution** (from normalised UA and device type)
- **Abuse detection**: same `ip_hash` appearing in both upload and download events within a day suggests the sender downloaded their own file (or potential abuse); same `asn_hash` with high volume suggests network-level abuse
- **VPN/Tor usage rates** (direct from boolean flags)
- **TLS adoption** (direct from TLS version field)
- **Threat intelligence** correlation (boolean flag)

Analytics You Lose (By Design)

- Cross-day IP correlation (hashes rotate daily — this is the privacy feature)
- Exact timing correlation (hour granularity only)
- Geographic precision below city level
- User-Agent fingerprinting / browser version tracking
- ISP-level analytics (hashed ASN preserves correlation but not identity)

Implementation Checklist

1. **DPIA (Data Protection Impact Assessment)**: Required under Art. 35 GDPR given the volume of processing and the novel transparency panel feature. Document the three-tier classification, hashing scheme, salt lifecycle, and rationale for each decision.
 2. **Privacy Notice**: Update to reflect what you collect, why (legitimate interest), what you store (anonymised/pseudonymised), and what you discard. The transparency panel itself serves as a powerful transparency mechanism — reference it in your privacy notice.
 3. **Lawful Basis**: Art. 6(1)(f) legitimate interest for all processing. The balance test is straightforward: minimal data, aggressive anonymisation, clear security/abuse-prevention purpose, no impact on data subjects.
 4. **Record of Processing Activities (Art. 30)**: Document the ephemeral processing of raw PII (IP, full UA, etc.) even though it's not persisted.
 5. **Salt Lifecycle Automation**: Implement and test the daily salt rotation. Use AWS Secrets Manager with a scheduled Lambda for rotation and deletion. Monitor for rotation failures — a stale salt that persists beyond 24h undermines the anonymisation claim.
 6. **City Population Threshold**: Maintain a lookup table (from GeoNames or similar) mapping city names to approximate populations. Suppress any city below 50k population to "—" before storage.
 7. **Regular Review**: Re-assess annually as regulations evolve. The EDPB's pseudonymisation guidelines (01/2025) are still in consultation as of early 2025 — the final version may change the analysis.
-

Key Legal References

Reference	Relevance
CJEU C-582/14 <i>Breyer v Bundesrepublik Deutschland</i> (2016)	Dynamic IP addresses are personal data
GDPR Art. 4(1), 4(5), Art. 5(1)(c), Art. 6(1)(f), Art. 25, Art. 35, Recital 26, Recital 30	Core definitions, minimisation, legitimate interest, privacy by design, DPIA
EDPB Guidelines 01/2025 on Pseudonymisation (Jan 2025, draft)	Pseudonymised data remains personal data; hashing is pseudonymisation
ICO Guidance on Anonymisation and Pseudonymisation (Mar 2025)	"Motivated intruder" test; effective anonymisation when re-identification sufficiently remote
Article 29 Working Party Opinion WP136 (2007)	IP addresses should be treated as personal data by default
Dutch DPA guidance on hashing	Hash values are reproducible via brute force on small input spaces
CCPA §1798.140(v)	IP addresses explicitly enumerated as personal information
LGPD Art. 5(I), Art. 12(2)	Personal data definition; anonymisation provisions
ePrivacy Directive Art. 5(3), Art. 6	Traffic data retention; consent requirements
EFF Panoptick (Eckersley, 2010)	User-Agent contributes ~10 bits of entropy; 83.6% of browsers uniquely identifiable
CJEU C-70/10 <i>Scarlet Extended</i>	IP addresses are personal data in the hands of ISPs
General Court T-557/20 <i>SRB v EDPS</i> (2023)	Data pseudonymised by sender may be anonymous to recipient lacking re-identification means